

The ISO/IEC 27005:2022 process and its steps

✓ From method to process: what the auditor will come looking for



Session objectives

By the end of this lecture:

- **Position** ISO/IEC 27005:2022: what it is, what it is not, and what links it to ISO/IEC 27001:2022 and ISO 31000:2018
- **Walk through** the risk management process: context establishment, risk assessment, risk treatment, risk acceptance, communication, monitoring and review

- **Distinguish** risk identification, risk analysis and risk evaluation, the three phases of risk assessment that everyone confuses
- **Explain** how EBIOS Risk Manager and ISO 27005 fit together, with the vocabulary correspondence table
- **Choose** between the four families of treatment options, knowing what each one commits to and does not commit to

Prerequisites

- Workshops 1 and 2 conducted in session 5: framing, security baseline, feared events, risk origin / target objective pairs, and the scales of deliverable D5.
- The strategic and operational scenarios built in session 6 through the group's ecosystem.
- The audit report from session 4: its deviations now live in the study's security baseline.
- The cost-of-inaction argument prepared this morning: it will serve in the treatment trade-off.

Today's shift of focus

Since session 5, this module has been putting a method into practice: workshops, participants, deliverables, concrete work. Today, the viewpoint moves up one notch: behind the method there is a process, that is, a sequence of activities that the organization repeats, records and improves, independently of the method chosen to execute it. The nuance sounds academic; it is very practical. When an auditor, a client or an authority examines the group's risk management, they do not ask "did you hold workshops"; they ask "show me your process: how do you identify, how do you decide, who accepts, and how does this live over time". This lecture provides that language, the language of the standardized process, and it answers the question every student who has made it this far is asking: EBIOS Risk Manager and ISO/IEC 27005, does one choose one against the other?

✓ Three texts, three verbs: require, recommend, equip

The map laid out in session 5, recapped in one sentence per text, before adding the layer that was missing. ISO 31000:2018, « Management du risque : Principes et lignes directrices » (risk management, principles and guidelines) by its official title, lays down the principles of risk management for every type of risk. ISO/IEC 27001:2022, « Exigences » (requirements), requires a certified organization to assess and treat its information security risks. And EBIOS Risk Manager equips that work with concrete workshops. Between the requirement and the tool, one place remained: that of the guide describing the process itself.

Concept sheet: ISO/IEC 27005:2022

The problem it answers: the requirements standard says risk must be managed, without saying how to go about it; an organization left to itself then invents an incomplete process, forgets formal acceptance or monitoring, and discovers this in an audit. What it is: the international guidance for managing information security risks; the bibliography of the EBIOS RM guide cites it under its French title, « Préconisation pour la gestion des risques liés à la sécurité de l'information », and its English title in the catalogue is "Guidance on managing information security risks". Its fourth edition, published in October 2022, cancels and replaces the 2018 edition, with a reworked structure: a practitioner who cites the old organization of the text immediately dates their knowledge. Its mechanics: describing the risk management process, its activities and how they follow one another, consistent with the requirements of 27001 and the principles of 31000. Its limits, two of them: it is guidance, one does not get certified against it, one draws on it; and it is a text that describes WHAT to do at each step, not a facilitation method, which is precisely the space EBIOS RM occupies. One last practical point: like all ISO standards, its text must be purchased; the work will therefore be done, in this module as often in companies, with the process it describes as rendered by the accessible official documents, the ANSSI guide first among them.

Text	Its verb	What it is used for	What it cannot be used for
ISO 31000:2018	Lay down the principles	The conceptual foundation, for all types of risk	Using it as a security how-to manual
ISO/IEC 27001:2022	Require	Getting certified, proving the management system	Finding the detail of the risk process in it
ISO/IEC 27005:2022	Recommend	Building and evaluating one's risk process	Getting certified against it
EBIOS Risk Manager	Equip	Running the workshops, producing the deliverables	Waving it around as a label or a certificate

This table settles the question of choice: nobody chooses between ISO 27005 and EBIOS RM, they are stacked. The process provides the structure and the audit language, the method provides the workshops and the deliverables. The EBIOS RM guide says it itself: its recent evolutions are « notamment pour vocation à rendre la méthode pleinement conforme à la norme ISO/CEI 27005:2022 » (intended in particular to make the method fully compliant with ISO/IEC 27005:2022). The compliance claim is made by the official text: that is the exact argument to serve an auditor.

The risk management process: six moments that loop

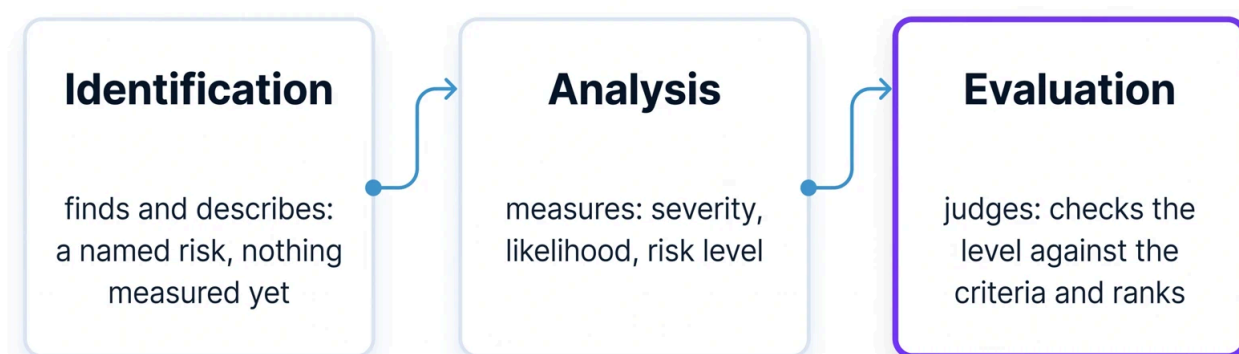
Here is the process, as the family of risk management standards structures it and as this module has had it practiced for three sessions without yet naming it. Six moments, one of which encompasses three phases.

Process moment	The question it answers	What comes out of it	Where it has already been practiced
Context establishment	What does risk management cover, with which criteria and which scales?	Scope, parties involved, scales and acceptance thresholds	Workshop 1, deliverable D5 (session 5)
Risk assessment: identification	What are the risks, described and named?	The list of risks, with associated sources and events	Workshops 2 and 3 (sessions 5 and 6)
Risk assessment: analysis	What level does each risk reach?	Severity, likelihood, risk level	Workshop 4, rating (session 6 and this afternoon)
Risk assessment: evaluation	Is that level acceptable against the criteria?	The risks ranked against the acceptance line	The D5 acceptance line, applied this afternoon
Risk treatment	What is decided for each risk above the line?	Chosen options, measures, treatment plan, residual risk	Workshop 5, deliverable D7 (this afternoon)
Risk acceptance	Who formally owns what remains?	Acceptance decisions signed by the legitimate body	Executive management, designated from the framing stage
Communication and consultation	Who knows what, when, and who has been heard?	Governance bodies, participants, strategy notes	The workshops themselves, the note to the Executive Committee
Monitoring and review	What has changed, and what needs revising?	Indicators, reviews, updates to the study	The cycles set in workshop 1, this afternoon's follow-up

Two properties of this table deserve to be said outright. First, communication and monitoring are not final steps: they are continuous activities that accompany all the others; that is why the process is drawn as a loop and not as a line. Second, the right-hand column shows something important for the student's confidence: this process is not being discovered today, it has been running since session 5. The lecture does not teach how to do it; it gives the standardized name of what is already being done, and that name is the one the outside world understands.

The process is iterative, and the requirements standard places it in the continuous improvement cycle of management systems, the PDCA (plan, do, check, act). Risk assessment and the treatment plan belong to the first phase, the execution of the measures to the second, monitoring and review to the third, the update of the study to the fourth, before starting again. A frozen risk analysis is a dead one: a scope that changes, a third party that changes, an incident that happened elsewhere, and the register describes an organization that no longer exists. That is why workshop 1 sets two cycles, strategic and operational, and why the management review makes it a fixed item on its agenda.

A stop is needed on the central moment, risk assessment, because its three phases carry names so close that they crush one another in student papers and in meetings. The glossary of the EBIOS RM guide defines risk assessment as « Ensemble du processus d'identification, d'analyse et d'estimation des risques (ISO 31000:2018) » (the overall process of risk identification, analysis and estimation), and specifies that in the EBIOS RM approach it corresponds to workshops 2, 3 and 4. Three phases, then. **Identification** finds and describes: at its output, each risk exists as a named object, a source, a path, a feared event; nothing is measured yet. **Analysis** measures: it estimates severity and likelihood and derives the risk level from them; nothing is judged yet. **Evaluation** judges: it compares the level obtained against the criteria set at context establishment, the acceptance line derived from the group's risk appetite, and it ranks: acceptable, tolerable under conditions, to be treated. The classic confusion is saying "we evaluated the risk" when meaning "we rated it": rating is analysis; evaluating is confronting the rating with the threshold and preparing the decision. A process that skips evaluation produces magnificent risk maps and never decides anything.



Two markers of the 2022 edition complete this reading. First the risk criteria, aligned with requirement 6.1.2 a) of ISO/IEC 27001:2022, which come in two kinds: the risk acceptance criteria, which translate management's appetite into thresholds, and the criteria for performing risk assessments, which set how an assessment is conducted so that two assessments are comparable, scales, method, scope, frequency. The MERIDIAN group set both in

workshop 1, the acceptance line on one side, the justified scales of D5 on the other, and management decides them, because they translate its appetite. Then the choice of approach. The guidance describes an event-based approach, which starts from what the organization fears and works down to the scenarios, and an asset-based approach, which starts from the inventory and looks for the vulnerabilities of each asset. EBIOS RM belongs to the first, and that is what justified, in session 5, starting from business assets and feared events rather than from a list of servers; the asset-based approach keeps its use on a narrow technical scope, but it would not have produced a scenario going through the software vendor or the hosting provider.

✓ EBIOS RM and ISO 27005: the fit, finally spelled out

The question deserved better than an intuition; here it is dealt with for good. The French method and the international guidance do not overlap: they interlock, and the interlocking can be verified at two levels.

At the process level first: each moment of the previous table finds its execution in one or more workshops. Workshop 1 executes context establishment, framing, scales and baseline included; workshops 2 and 3 execute identification, from the risk origin / target objective pair to the strategic scenario; workshop 4 carries most of the analysis, likelihood coming to complete the severity inherited from the feared events; workshop 5 executes evaluation, treatment, acceptance and sets up monitoring. The method is, in the literal sense, an implementation of the process: that is exactly what "compliant" means.

At the vocabulary level next, and this is the trap in student papers and calls for tenders alike: the two texts do not name the same objects the same way. The glossary of the EBIOS RM guide itself carries the translation table, in notes that few readers notice and that are worth gold:

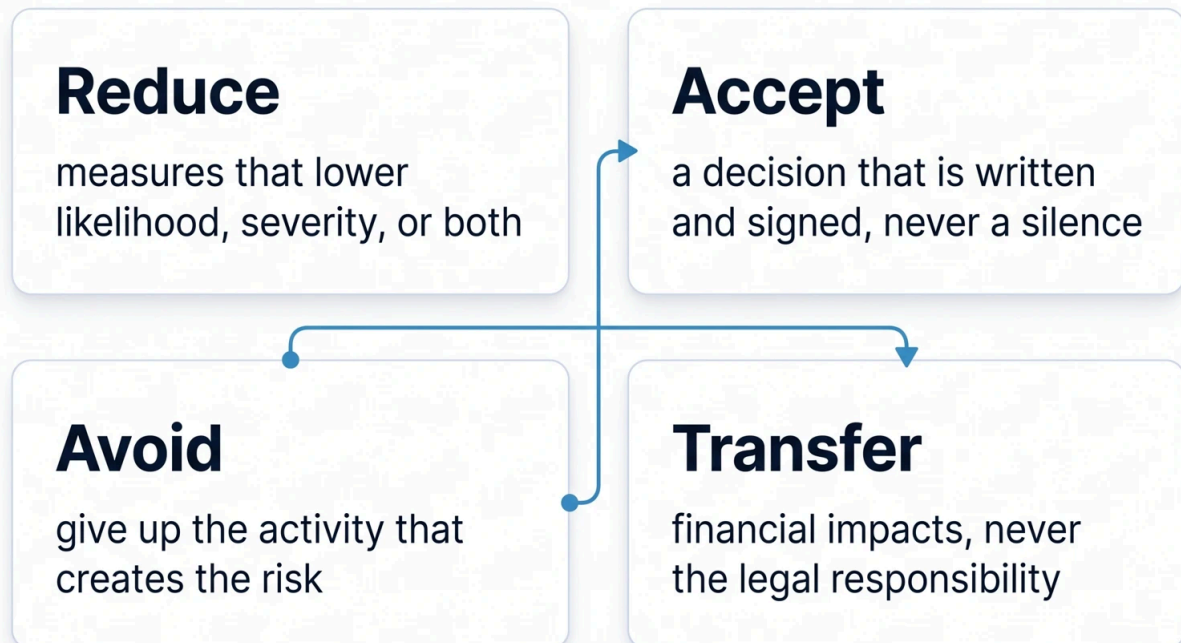
EBIOS Risk Manager	ISO 27005	The exact note in the EBIOS glossary
Business asset	Primary asset	« dans la norme ISO 27005, les valeurs métiers correspondent aux “biens primaires” » (in ISO 27005, business assets correspond to “primary assets”)
Security need	Security objective	« dans la norme ISO 27005 les besoins de sécurité correspondent aux “objectifs de sécurité” » (in ISO 27005, security needs correspond to “security objectives”)
Feared event	Consequence	« dans la norme ISO 27005, les événements redoutés correspondent aux “conséquences” » (in ISO 27005, feared events correspond to “consequences”)
Stakeholder	Interested party	« Dans la norme ISO 27005, une partie prenante correspond à une “partie intéressée” » (in ISO 27005, a stakeholder corresponds to an “interested party”)
Intermediate event	Intermediate consequence	« dans la norme ISO 27005, l'évènement intermédiaire correspond à une “conséquence intermédiaire” » (in ISO 27005, the intermediate event corresponds to an “intermediate consequence”)

This table has in fact already been encountered without being named: the group's GRC (governance, risk and compliance) tool displays « Conséquence » (consequence) on the axis that deliverable D5 calls severity of feared events. That was not a translation oversight; it was the vocabulary of the standardized process surfacing in the tool. A group CISO is bilingual out of necessity: they run their workshops in EBIOS, they answer auditors and write their policies in the standard's vocabulary, and they know how to move from one to the other without losing an object along the way. It is a skill that gets assessed, and the end-of-module oral defense will pay attention to it.

✓ Risk treatment: four families of decision

The process leads to its reason for being: deciding. For each risk that evaluation places above the line, risk management practice sorts the possible decisions into four families, which the group's tool moreover reflects in the treatment statuses of its scenarios. **Reduce:** put in place measures that lower the likelihood, the severity, or both; it is the default family, the one that fills the treatment plans. **Accept:** decide, explicitly and at the right level, to carry the risk as it stands; acceptance is a decision that is written down and signed, never a silence that settles in. **Avoid:** give up the activity or the architecture that creates the risk; it is the family nobody remembers to propose, even though dropping a flow, closing an exposed service or refusing a project is sometimes the only proportionate answer. **Transfer:** have part of the risk carried by a third party, through insurance or contract; with one limit every executive must hear: financial impacts and contractual obligations can be transferred, legal liability and harm to people cannot. An insurance policy has never treated a patient.

Four families of decision



The EBIOS RM guide lights the same decision from the other end: rather than starting from the families of options, its workshop 5 starts from the risk levels and recommends acceptance classes, phrased as follows: a low-level risk is « Acceptable en l'état » (acceptable as is), and « aucune action n'est à entreprendre » (no action is to be taken); a medium risk is « Tolérable sous contrôle » (tolerable under control), with follow-up and continuous improvement actions; a high risk is « Inacceptable » (unacceptable), and « des mesures de réduction du risque doivent impérativement être prises à court terme » (risk reduction measures must imperatively be taken in the short term). The two grids overlay without friction: the acceptance class says whether to act, the option family says how. And the entire decision is formalized in what the guide calls the risk treatment strategy, which « formalise les seuils d'acceptation du risque et un niveau de sécurité à atteindre en cas de non-acceptation » (formalizes the risk acceptance thresholds and a security level to be reached in case of non-acceptance).

Two real cases to give these families weight. Norsk Hydro, in 2019, illustrates an acceptance worthy of the name: facing the ransomware, management had what it needed to decide fast, it refused to pay, owned the switch to manual operations and its operational cost; the operational risk was accepted knowingly, the unacceptable had been identified before the crisis. Conversely, the Centre Hospitalier Sud Francilien, hit by ransomware in 2022 and forced into a long period of degraded operations, is a reminder of what a risk that nobody has formally treated or accepted really is: it does not disappear, it waits; and when the day comes, the organization discovers it had "accepted" by default what no governance body would have accepted in writing. The whole value of the process lies in that gap: turning suffered acceptances into signed decisions.

Norsk Hydro, 2019

deliberate acceptance

- refusal to pay, deliberate switch to manual operations
- the unacceptable identified before the crisis

Centre Hospitalier Sud Francilien, 2022

acceptance by default

- risk never formally treated nor accepted
- degraded operations discovered on the day

✓ The residual and the register: what the process leaves behind

Treating does not make the risk disappear, and the process's final vocabulary serves to look at what remains. The **residual risk** is defined by the EBIOS glossary as the « Scénario de risque subsistant après application de la stratégie de traitement du risque » (risk scenario remaining after the risk treatment strategy has been applied), rated like the initial risk on severity and likelihood. Two consistency rules frame it, and the group's tool checks them mechanically: a residual is rated AFTER the measures have been decided, never before; and a residual cannot be higher than the initial risk, otherwise the "treatment" makes things worse. The residual is then confronted with the same acceptance line as the initial: if it stays above, either the treatment must be reinforced, or a justified derogatory acceptance must be obtained from the legitimate body. This requirement appears word for word in the criteria of tonight's deliverable.

The **risk register** is the form all of this takes over time: the living inventory of the risks in the scope, each with its rating, its treatment decision, its owner, its deadline and its residual. The register is not one more document: it is the object that monitoring keeps alive, the one the auditor opens first, and the one the risk analysis in the GRC tool already materializes, scenario by scenario. As for monitoring itself, the EBIOS guide describes it unambiguously: « Le management du risque, notamment le suivi des risques, doit s'appuyer sur des indicateurs de pilotage » (risk management, and risk follow-up in particular, must rely on steering indicators), a steering committee meets at regular intervals, and « cette surveillance est un processus régulier et permanent » (this

monitoring is a regular and permanent process), backed by the two cycles set from workshop 1 onward. A register that has not moved in a year does not prove the risk is stable; it proves monitoring is dead.

✓ What the afternoon will do with all of this

The rest of the day executes the end of the process on the MERIDIAN group. The tutorial applies the rating matrices and has the treatment options chosen on the group's scenarios. The lab goes back in detail through workshop 4, the estimation of likelihoods, and completes the register in the tool. The final sequence assembles the treatment plan and the residual risk into deliverable D7, and the strategy note gains its treatment subsection. One last warning before practicing: the process standardizes the work, not the lucidity. It guarantees that the questions are asked in order and recorded; it does not guarantee that the answers are right, and an impeccably kept register can rigorously describe a reality nobody wanted to see. The standard provides the frame; judgment remains the craft of the CISO.

+200 XP

Formation terminée !